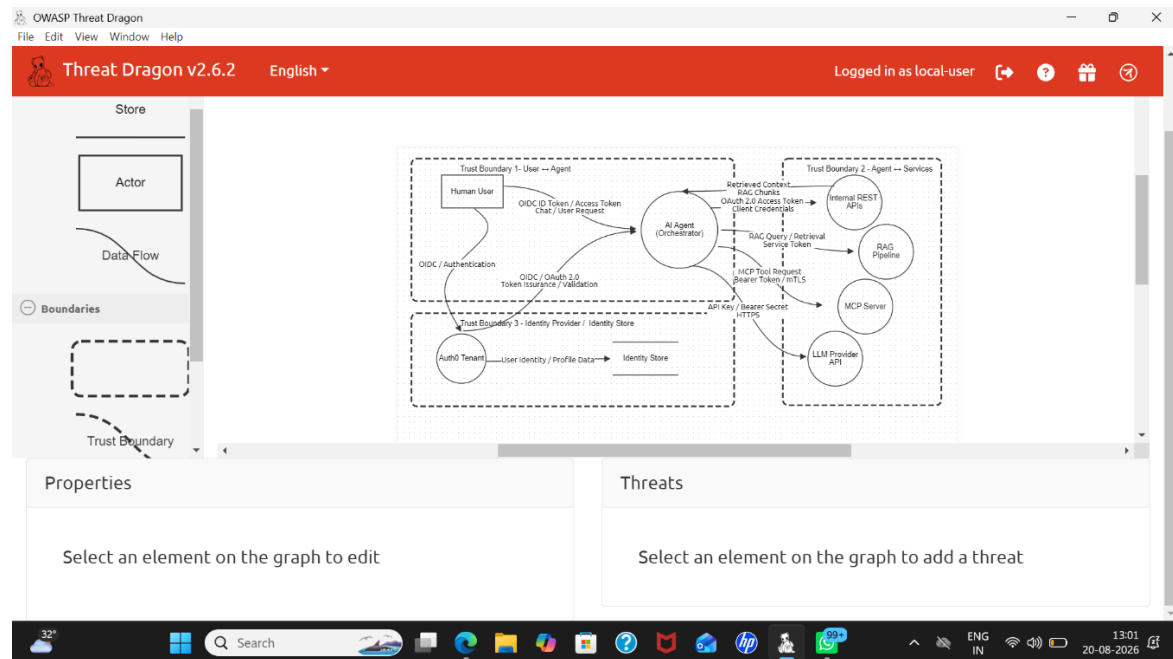


# SECURENOVA AI IDENTITY SECURITY

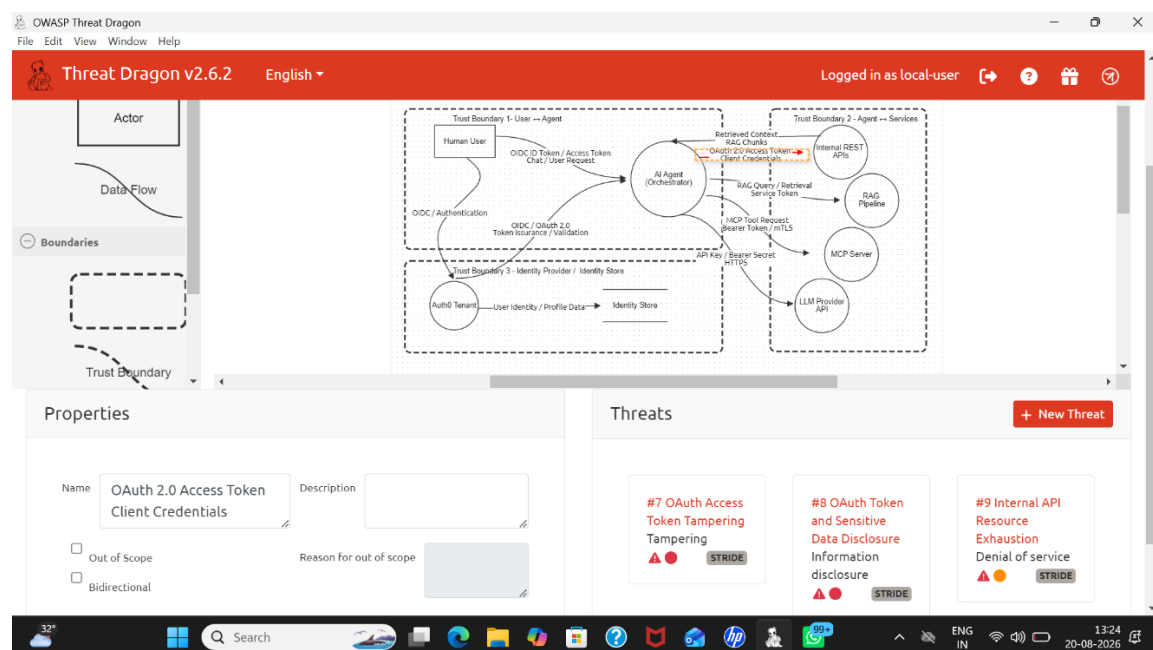
## PROJECT 1 — THREAT MODELING & RISK ANALYSIS

### Screenshot 1: SecureNova AI Identity Security Threat Model



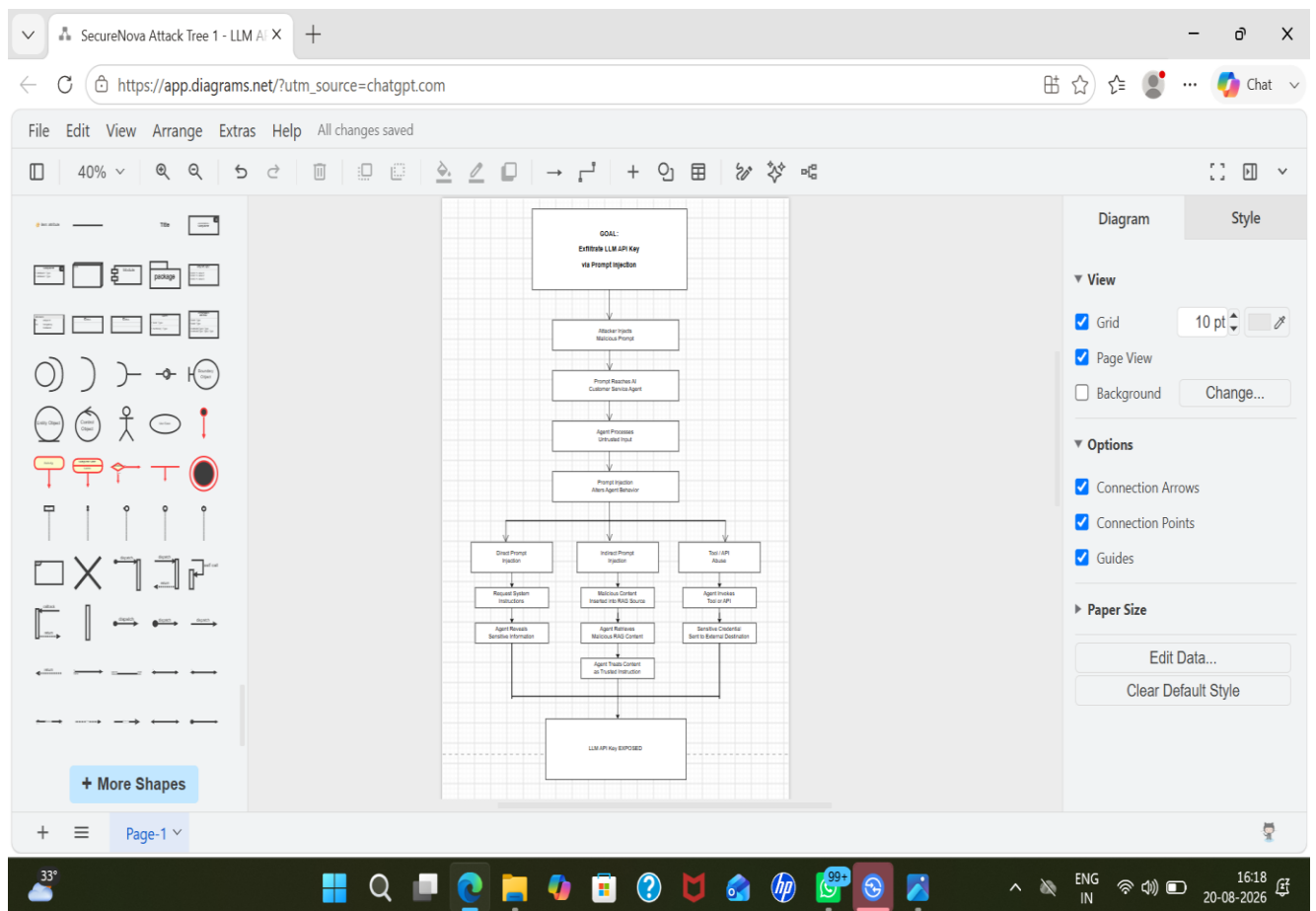
This screenshot shows the overall SecureNova AI Identity Security threat model created using OWASP Threat Dragon. It identifies the human user, AI agent, Auth0 identity provider, internal REST APIs, RAG pipeline, MCP server, LLM provider, identity store, trust boundaries, and security-sensitive data flows.

### Screenshot 2: Threat Identification in OWASP Threat Dragon



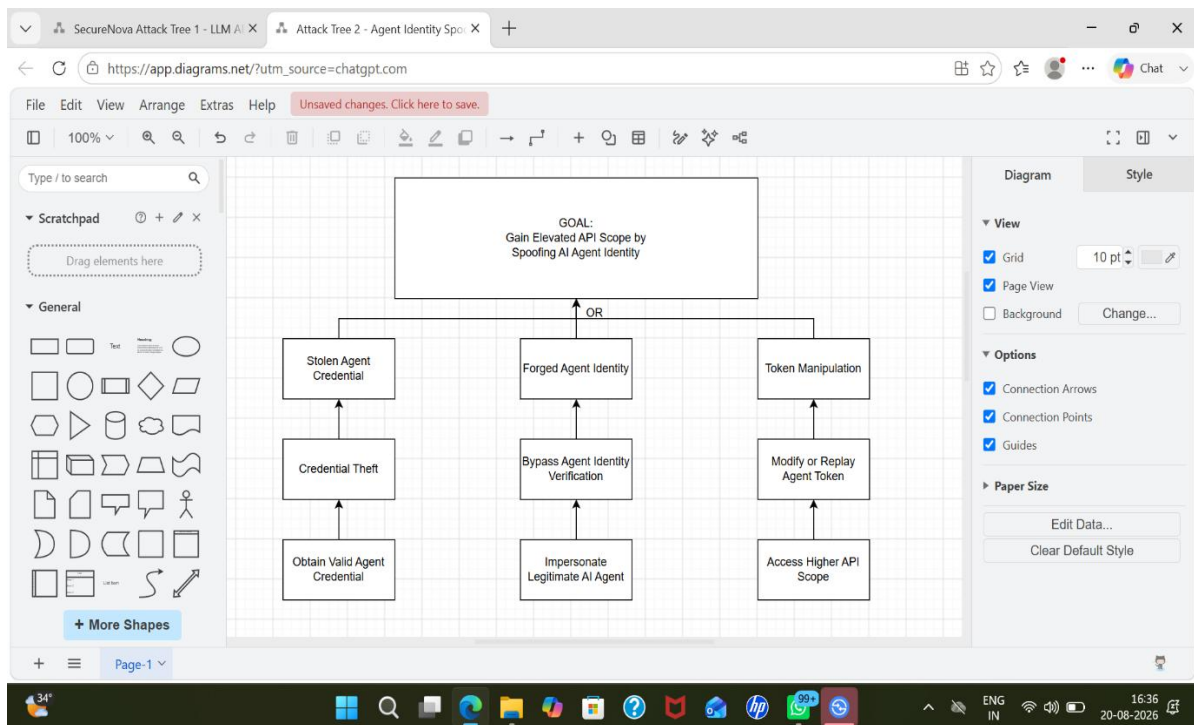
*This screenshot demonstrates the identification and documentation of security threats within the SecureNova architecture using OWASP Threat Dragon. The threats are associated with specific system components and data flows and are classified using the STRIDE methodology.*

### Screenshot 3: Attack Tree 1 — LLM API Key Exfiltration



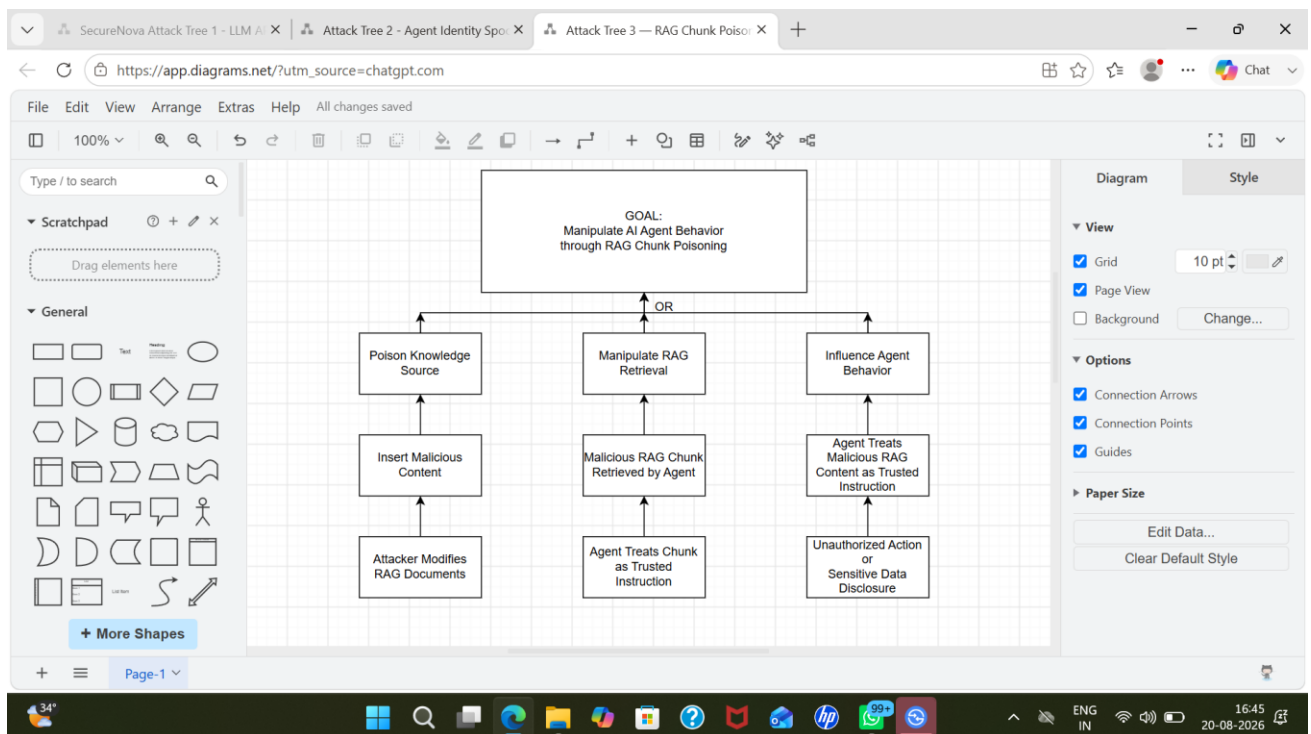
*This attack tree models how an attacker could exfiltrate an LLM API key through prompt injection. It considers direct prompt injection, indirect prompt injection through malicious RAG content, and tool/API abuse as alternative attack paths leading to exposure of the LLM API key.*

## Screenshot 4: Attack Tree 2 — AI Agent Identity Spoofing



*This attack tree models attacks against the AI agent identity layer. It shows how stolen credentials, forged agent identity, or token manipulation could allow an attacker to impersonate an AI agent and obtain elevated API privileges.*

## Screenshot 5: Attack Tree 3 — RAG Chunk Poisoning



*This attack tree models RAG chunk poisoning attacks against the SecureNova AI agent. It demonstrates how malicious content can be inserted into RAG sources, retrieved by the AI agent, and incorrectly treated as trusted instructions, potentially resulting in unauthorized actions or sensitive data disclosure.*

## Screenshot 6: STRIDE Threat Matrix

| Identity / Flow               | Spoofing (S)                | Tampering (T)               | Repudiation (R)               | Information Disclosure (I)    | Denial of Service (D)           | Elevation of Privilege (E)  |
|-------------------------------|-----------------------------|-----------------------------|-------------------------------|-------------------------------|---------------------------------|-----------------------------|
| Human User → AI Agent         | Stolen user credentials     | Manipulated user request    | Missing user activity logs    | Sensitive response exposed    | Excessive user requests         | Unauthorized role access    |
| Auth0 → AI Agent              | Forged authentication token | Modified JWT claims         | Missing authentication logs   | Token information exposed     | Authentication request flooding | Excessive token scope       |
| AI Agent → Internal REST APIs | Forged agent identity       | Modified API request        | Insufficient agent audit logs | Sensitive API data exposed    | API resource exhaustion         | Unauthorized API scope      |
| AI Agent → RAG Pipeline       | Fake RAG service identity   | RAG chunk poisoning         | Unlogged retrieval activity   | Sensitive knowledge retrieved | Excessive retrieval requests    | Malicious RAG instruction   |
| AI Agent → MCP Server         | Forged MCP server identity  | Modified MCP tool request   | Missing tool invocation logs  | Sensitive tool output exposed | MCP tool flooding               | Unauthorized tool execution |
| AI Agent → LLM Provider API   | Stolen LLM API key          | Modified LLM API parameters | Untracked API calls           | LLM API key exposure          | API quota exhaustion            | Unauthorized model access   |

*This STRIDE matrix systematically analyzes the SecureNova AI identity architecture against Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege threats. The analysis is performed across the major identity and service flows identified in the Threat Dragon model.*

Screenshot 7: SecureNova Risk Register

AutoSave OFF Stride • Saved to this PC Search

File Home Insert Draw Page Layout Formulas Data Review View Automate Help

Clipboard Font Alignment Number Styles Cells Editing Add-ins

Q4

|   | A       | B                             | C      | D                                                          | E             | F          | G      | H          | I           | J                                                                      | K                 | L                       |
|---|---------|-------------------------------|--------|------------------------------------------------------------|---------------|------------|--------|------------|-------------|------------------------------------------------------------------------|-------------------|-------------------------|
| 1 | Risk ID | Identity Flow                 | STRIDE | Threat                                                     | Attack Tree   | Likelihood | Impact | Risk Score | Risk Level  | Mitigation                                                             | Owner             | MITRE ATLAS             |
| 2 | R-04    | Auth0 + AI Agent              | E      | Excessive OAuth scope provides unauthorized privileges     | Attack Tree 2 |            | 4      | 5          | 20 Critical | Least privilege scopes, scope validation, RBAC                         | IAM Team          | Agent Identity Spoofing |
| 3 | R-05    | AI Agent + RAG Pipeline       | T      | Malicious RAG chunks are inserted or modified              | Attack Tree 3 |            | 4      | 5          | 20 Critical | Document validation, provenance checks, content scanning               | AI Security Team  | RAG Chunk Poisoning     |
| 4 | R-06    | AI Agent + LLM Provider API   | I      | LLM API key or sensitive prompt data is exposed            | Attack Tree 1 |            | 4      | 5          | 20 Critical | Secret vault, key rotation, prompt filtering, DLP                      | AI Security Team  | Prompt Injection        |
| 5 | R-09    | AI Agent + Internal REST APIs | S      | Attacker impersonates the legitimate AI agent              | Attack Tree 2 |            | 4      | 5          | 20 Critical | Strong service identity, OAuth client authentication, token validation | API Security Team | Agent Identity Spoofing |
| 6 | R-12    | AI Agent + Internal REST APIs | E      | AI agent obtains unauthorized API scope                    | Attack Tree 2 |            | 4      | 5          | 20 Critical | Fine-grained scopes, RBAC, resource-level authorization                | IAM Team          | Agent Identity Spoofing |
| 7 | R-14    | AI Agent + RAG Pipeline       | T      | Malicious RAG chunks or documents are inserted or modified | Attack Tree 3 |            | 4      | 5          | 20 Critical | Document validation, provenance verification, content scanning         | AI Security Team  | RAG Chunk Poisoning     |

Sheet1 Risk Register

Ready Accessibility: Investigate

30° ENG IN 02:06 22-08-2026

AutoSave OFF Stride • Saved to this PC Search

File Home Insert Draw Page Layout Formulas Data Review View Automate Help

Clipboard Font Alignment Number Styles Cells Editing Add-ins

Q4

|    | A    | B                           | C | D                                                      | E             | F | G | H | I           | J                                                                                              | K                 | L                   |
|----|------|-----------------------------|---|--------------------------------------------------------|---------------|---|---|---|-------------|------------------------------------------------------------------------------------------------|-------------------|---------------------|
| 8  | R-17 | AI Agent + RAG Pipeline     | E | Malicious RAG content causes unauthorized agent action | Attack Tree 3 |   | 4 | 5 | 20 Critical | Treat retrieved content as untrusted; separate instructions from data                          | AI Security Team  | RAG Chunk Poisoning |
| 9  | R-23 | AI Agent + MCP Server       | E | Unauthorized MCP tool execution                        | —             |   | 4 | 5 | 20 Critical | Tool-level authorization, allowlists, least-privilege credentials                              | API Security Team | —                   |
| 10 | R-24 | AI Agent + LLM Provider API | S | Stolen LLM API key is used by an attacker              | Attack Tree 1 |   | 4 | 5 | 20 Critical | Secret vault, short-lived credentials, key rotation, access monitoring                         | AI Security Team  | Prompt Injection    |
| 11 | R-27 | AI Agent + LLM Provider API | I | LLM API key or sensitive prompt data is exposed        | Attack Tree 1 |   | 4 | 5 | 20 Critical | Secret management, prompt injection guardrails, DLP, output filtering                          | AI Security Team  | Prompt Injection    |
| 12 | R-02 | Human User + AI Agent       | T | Malicious prompt modifies intended AI agent behavior   | Attack Tree 1 |   | 4 | 4 | 16 High     | Input validation, prompt filtering, instruction JAIL signature validation, issuer and audience | AI Security Team  | Prompt Injection    |

Sheet1 Risk Register

Ready Accessibility: Investigate

30° ENG IN 02:06 22-08-2026

AutoSave

Stride • Saved to this PC

Search

FileHomeInsertDrawPage LayoutFormulasDataReviewViewAutomateHelp

Clipboard

Paste

Aptos Narrow11

B I U

Font

Alignment

General

Number

Conditional Formatting

Format as Table

Cell Styles

Styles

Insert

Delete

Format

Cells

Σ

Sort & Filter

Editing

Comments

Share

Find & Select

Add-ins

Q4

fx

| A  | B    | C                             | D | E                                                                      | F             | G | H | I  | J        | K                                                                                        | L                  |                         |
|----|------|-------------------------------|---|------------------------------------------------------------------------|---------------|---|---|----|----------|------------------------------------------------------------------------------------------|--------------------|-------------------------|
| 13 | R-03 | Auth0 → AI Agent              | S | Forged or stolen authentication token impersonates legitimate identity | Attack Tree 2 | 3 | 5 | 15 | High     | JWT signature validation, issuer and audience validation, short token                    | IAM Team           | Agent Identity Spoofing |
| 14 | R-07 | Auth0 → AI Agent              | T | Authentication token or JWT claims are modified                        | Attack Tree 1 | 3 | 5 | 15 | Critical | JWT signature validation, strict claim validation, token integrity checks                | IAM Team           | Agent Identity Spoofing |
| 15 | R-11 | AI Agent → Internal REST APIs | I | Sensitive internal API data is exposed to an unauthorized agent        | Attack Tree 2 | 3 | 5 | 15 | High     | API-level authorization, data filtering, least-privilege access                          | API Security Team  | Agent Identity Spoofing |
| 16 | R-16 | AI Agent → RAG Pipeline       | I | Sensitive information is retrieved from the knowledge base             | Attack Tree 3 | 3 | 5 | 15 | High     | Access-controlled retrieval, data classification, sensitive-data filtering               | Data Security Team | RAG Chunk Poisoning     |
| 17 | R-18 | AI Agent → MCP Server         | S | Forged MCP server or service identity is accepted                      | —             | 3 | 5 | 15 | High     | Mutual TLS, strong service identity, certificate validation<br>Tool-level authentication | API Security Team  | —                       |

< >

Sheet1Risk Register

+

ReadyAccessibility: Investigate

30°

Windows Taskbar

ENG IN

20:07 22-08-2026

*This risk register consolidates the security risks identified through the STRIDE analysis and attack trees. Each risk is assigned a risk score and severity level, with corresponding mitigation measures, responsible ownership, and MITRE ATLAS mapping where applicable.*

## Screenshot 8: MITRE ATLAS Technique Mapping

**MITRE ATLAS**

Home > Techniques > RAG Poisoning

# RAG Poisoning

Adversaries may inject malicious content into data indexed by a retrieval augmented generation (RAG) system to contaminate a future thread through RAG-based search results. This may be accomplished by placing manipulated documents in a location the RAG indexes (see [Gather RAG-Indexed Targets](#)).

The content may be targeted such that it would always surface as a search result for a specific user query. The adversary's content may include false or misleading information. It may also include prompt injections with malicious instructions, or false RAG entries.

**ID:** AML.T0070

**Tactics:** [Persistence](#)

**Maturity:** [Demonstrated](#)

**Platforms:** [Agentic AI](#) [Generative AI](#)

**Number of Case Studies:** 3

**Number of Mitigations:** 2

**Created:** 12 March 2025

**Last Modified:** 27 May 2026

[Version Permalink \(v2026.07\)](#)

*This screenshot provides evidence of mapping the identified AI security threats to relevant MITRE ATLAS techniques. The mapping supports standardized classification of adversarial behaviors affecting AI agents, credentials, prompt injection, and AI system components.*

## **Conclusion**

Overall, this project helped identify the main security risks in SecureNova's AI identity system. Using **Threat Dragon, STRIDE, attack trees, and a risk register**, we identified threats like prompt injection, agent identity spoofing, and RAG poisoning. The analysis also helped define suitable security controls and prioritize the major risks that need to be addressed.